KỊCH BẢN THUYẾT TRÌNH 5 PHÚT – SAFEPAY GUARD

Quy ước: **chữ đậm** = ý bắt buộc phải nói; *[chữ đỏ trong ngoặc vuông]* = thao tác bấm slide, không đọc thành lời.

Phần lời nói khoảng 940 âm tiết; nói với tốc độ vừa phải (khoảng 190–200 âm tiết/phút) thì vừa 5 phút. Nên tập bấm giờ 1–2 lần. Có 19 slide nên không nói hết từng slide: những slide ghi "lướt" chỉ bấm qua kèm 1 câu. Phần **in đậm** là ý bắt buộc phải nói nếu bị hụt giờ.

Thời gian	Slide	Nội dung
0:00 – 0:20	1	Mở đầu
0:20 – 0:50	2	Bài toán
0:50 – 1:10	3, 4	Người dùng, tài sản, rủi ro (lướt)
1:10 – 1:40	5	Ý tưởng cốt lõi
1:40 – 2:00	6, 7	Kiến trúc, luồng phê duyệt (lướt)
2:00 – 2:30	8, 9	Cơ chế bảo vệ, chấm điểm rủi ro
2:30 – 3:15	10	Tình huống deepfake (trọng tâm)
3:15 – 3:45	11, 12, 13	BEC, chiếm tài khoản, sửa dữ liệu (lướt)
3:45 – 4:10	14	Bốn dạng đầu vào không đáng tin
4:10 – 4:30	15, 16	Prototype, kiểm thử
4:30 – 4:50	17	Trade-off
4:50 – 5:00	18, 19	Hạn chế, kết luận

Slide 1 – Mở đầu (0:00 – 0:20)

Em chào thầy/cô và các bạn. Nhóm em làm Hướng 1 – thiết kế hệ thống an toàn, với đề tài **SafePay Guard: hệ thống phê duyệt lệnh chuyển tiền chống giả mạo cho doanh nghiệp vừa và nhỏ**. Mục tiêu của tụi em là: một cuộc gọi deepfake của giám đốc, dù giống thật đến đâu, cũng không làm tiền của công ty bị chuyển đi.

Slide 2 – Bài toán (0:20 – 0:50)

Lừa đảo giả danh lãnh đạo hoặc nhà cung cấp gây thiệt hại khoảng 2,9 tỷ đô chỉ riêng ở Mỹ năm 2023. Năm 2024, một nhân viên Arup ở Hồng Kông chuyển 25 triệu đô sau một cuộc họp video mà mọi người trong đó đều là deepfake. Ở Việt Nam, thủ đoạn giả lãnh đạo qua Zalo cũng đã phổ biến.

Điểm yếu chung là **quy trình tin vào thứ "trông có vẻ thật"**: giọng nói, khuôn mặt, email, con dấu. Nên câu hỏi của đồ án là: **hệ thống dựa vào đâu để tin, kiểm chứng hay từ chối một yêu cầu?**

Slide 3, 4 – Người dùng, tài sản, rủi ro (0:50 – 1:10)

Người dùng là kế toán lập lệnh, kế toán trưởng và giám đốc duyệt lệnh. Kẻ tấn công có thể ở bên ngoài, chiếm tài khoản, hoặc là nội gián. *[bấm sang slide 4]* Tài sản chính là tiền, số tài khoản nhà cung cấp, quyền phê duyệt và nhật ký. Phân tích theo STRIDE ra 10 rủi ro, nặng nhất là giả danh lãnh đạo.

Slide 5 – Ý tưởng cốt lõi (1:10 – 1:40)

Đây là ý quan trọng nhất. **Tụi em không cố phát hiện deepfake, mà làm cho deepfake trở nên vô dụng.** Mọi thứ đến từ bên ngoài – giọng nói, video, email, ảnh hoá đơn, số tài khoản người ta đọc cho – đều chỉ là *lời khẳng định chưa xác minh*. Hệ thống chỉ tin ba thứ: **chữ ký số từ thiết bị đã đăng ký, sổ đăng ký nhà cung cấp lập từ lúc ký hợp đồng, và kết quả gọi lại tới số điện thoại lấy từ sổ đó.**

Slide 6, 7 – Kiến trúc, luồng phê duyệt (1:40 – 2:00)

Kế toán lập lệnh trên web, người duyệt ký trên điện thoại riêng, máy chủ kiểm tra rồi mới gửi sang ngân hàng. *[bấm sang slide 7]* Một lệnh đi qua ba bước tạo, duyệt, thực thi, và **ở bước thực thi mọi thứ được kiểm tra lại từ đầu**.

Slide 8, 9 – Cơ chế bảo vệ, chấm điểm rủi ro (2:00 – 2:30)

Có sáu cơ chế. Hai cơ chế chính là **chữ ký Ed25519 trên đúng nội dung lệnh** – thấy gì ký nấy – và **phê duyệt theo rủi ro**. *[bấm sang slide 9]* Mỗi lệnh được chấm điểm: đến từ kênh ngoài cộng 25, tự xưng lãnh đạo cộng 20, có chữ "gấp" cộng 15. Thông tin bên ngoài chỉ làm tăng điểm, không bao giờ làm giảm. Rủi ro cao thì cần 2 người duyệt, có giám đốc và gọi lại; còn số tài khoản lạ thì bị chặn luôn.

Slide 10 – Tình huống deepfake (2:30 – 3:15)

Ví dụ cụ thể: kế toán nhận cuộc gọi của "Giám đốc Nam" bảo chuyển gấp 300 triệu. Kế toán nhập lệnh, ghi nguồn là cuộc gọi, người tự xưng là giám đốc, hệ thống tính ra **80 điểm, rủi ro cao**. Kế toán trưởng và phó giám đốc duyệt rồi mà vẫn **chưa đủ, vì thiếu chữ ký của chính Giám đốc Nam trên điện thoại của ông ấy**. Nếu người duyệt gọi lại số mà "giám đốc" đọc trong cuộc gọi thì hệ thống từ chối, vì số đó không có trong danh bạ. Gọi số thật trong danh bạ, giám đốc nói "tôi không gọi", thế là lệnh bị huỷ và hệ thống bật cảnh báo.

Nếu đó là giám đốc thật thì sao? Thì giám đốc chỉ tốn thêm **một lần bấm ký**.

Slide 11, 12, 13 – BEC, chiếm tài khoản, sửa dữ liệu (3:15 – 3:45)

Email giả xin đổi số tài khoản: số cũ giữ nguyên, phải gọi lại số trong sổ, đổi thật cũng phải chờ 48 giờ. *[bấm sang slide 12]* Có mật khẩu, OTP, cả cookie phiên cũng không

duyệt được, vì thiếu khoá riêng trên điện thoại. *[bấm sang slide 13]* Sửa số tiền, sửa cơ sở dữ liệu hay sửa nhật ký đều bị phát hiện.

Slide 14 – Bốn dạng đầu vào không đáng tin (3:45 – 4:10)

Đề yêu cầu xử lý đầu vào bị giả mạo, chỉnh sửa, đánh cắp hoặc dùng sai ngữ cảnh, và tụi em xử lý **đủ cả bốn**. Dạng khó nhất là **dùng sai ngữ cảnh**: chữ ký thật nhưng của lệnh khác, OTP thật nhưng đã dùng rồi. Hệ thống chặn được vì mỗi chữ ký gắn với đúng lệnh, đúng quyết định và đúng thời hạn. Ảnh hoá đơn bị sửa số tài khoản cũng bị chặn, vì số tài khoản luôn lấy từ sổ.

Slide 15, 16 – Prototype, kiểm thử (4:10 – 4:30)

Prototype viết bằng Python Flask, có **15 kịch bản tấn công chạy được ngay trên web**. *[bấm sang slide 16]* Bộ kiểm thử có **33 test case, 38 lượt chạy, đạt 100%**, gồm cả tình huống bình thường lẫn tình huống tấn công.

Slide 17 – Trade-off (4:30 – 4:50)

An toàn thì phải trả giá. **Ngắn hạn**, lệnh gấp sẽ chậm hơn, và 48 giờ chờ có thể làm trễ thanh toán. **Dài hạn**, việc này thành thói quen, và nhân viên có lý do chính đáng để từ chối "sếp". Tụi em giảm bớt chi phí bằng cách **chỉ bật kiểm tra nặng khi rủi ro cao**, nên lệnh nhỏ thường ngày vẫn chỉ cần một người duyệt.

Slide 18, 19 – Hạn chế, kết luận (4:50 – 5:00)

Hệ thống vẫn phụ thuộc vào việc sổ đăng ký ban đầu phải đúng, và không chống được khi đủ số người duyệt cùng thông đồng. *[bấm sang slide 19]* Tóm lại: **chuyển niềm tin từ thứ "trông có vẻ thật" sang chữ ký số và dữ liệu đã xác minh.** Em cảm ơn thầy/cô và các bạn đã lắng nghe.

Nếu phải demo trong cùng 5 phút

Bỏ phần nói của slide 6, 7 và 11–13 (tiết kiệm khoảng 50 giây), rồi demo **KB04** trên web trong khoảng 60 giây:

1. Đăng nhập `ketoan`, tạo lệnh 300 triệu cho Phần mềm An Tâm. Chọn kênh "Cuộc gọi thoại", tự xưng `giamdoc`, đánh dấu khẩn cấp. Hệ thống hiện rủi ro CAO.
2. Đăng nhập `ketoantruong`, duyệt lệnh. Màn hình báo vẫn thiếu chữ ký Giám đốc và kết quả gọi lại.
3. Ghi nhận gọi lại số `0988 777 666` thì bị từ chối, vì số này không có trong danh bạ.

Mở sẵn `python prototype/app.py` và đăng nhập trước khi lên thuyết trình để không mất thời gian.

Câu hỏi thường gặp (chuẩn bị trước)

- **"Sao không dùng AI phát hiện deepfake?"** – AI phát hiện lỗi thời rất nhanh và khó giải thích. Hệ thống của tụi em đúng kể cả khi deepfake hoàn hảo. AI chỉ có thể dùng để cộng thêm điểm rủi ro.
- **"Nếu kẻ gian chiếm luôn điện thoại giám đốc?"** – Lệnh rủi ro cao vẫn cần thêm người duyệt thứ hai và gọi lại. Khi phát hiện, khoá khẩn cấp sẽ thu hồi thiết bị và huỷ các phê duyệt chưa thực thi (TC15).
- **"Lệnh nhỏ dưới 50 triệu có bị lọt không?"** – Đây là trade-off có chủ đích để vẫn tiện cho lệnh thường ngày. Lệnh nhỏ mà có dấu hiệu rủi ro vẫn bị nâng lên 2 người duyệt.